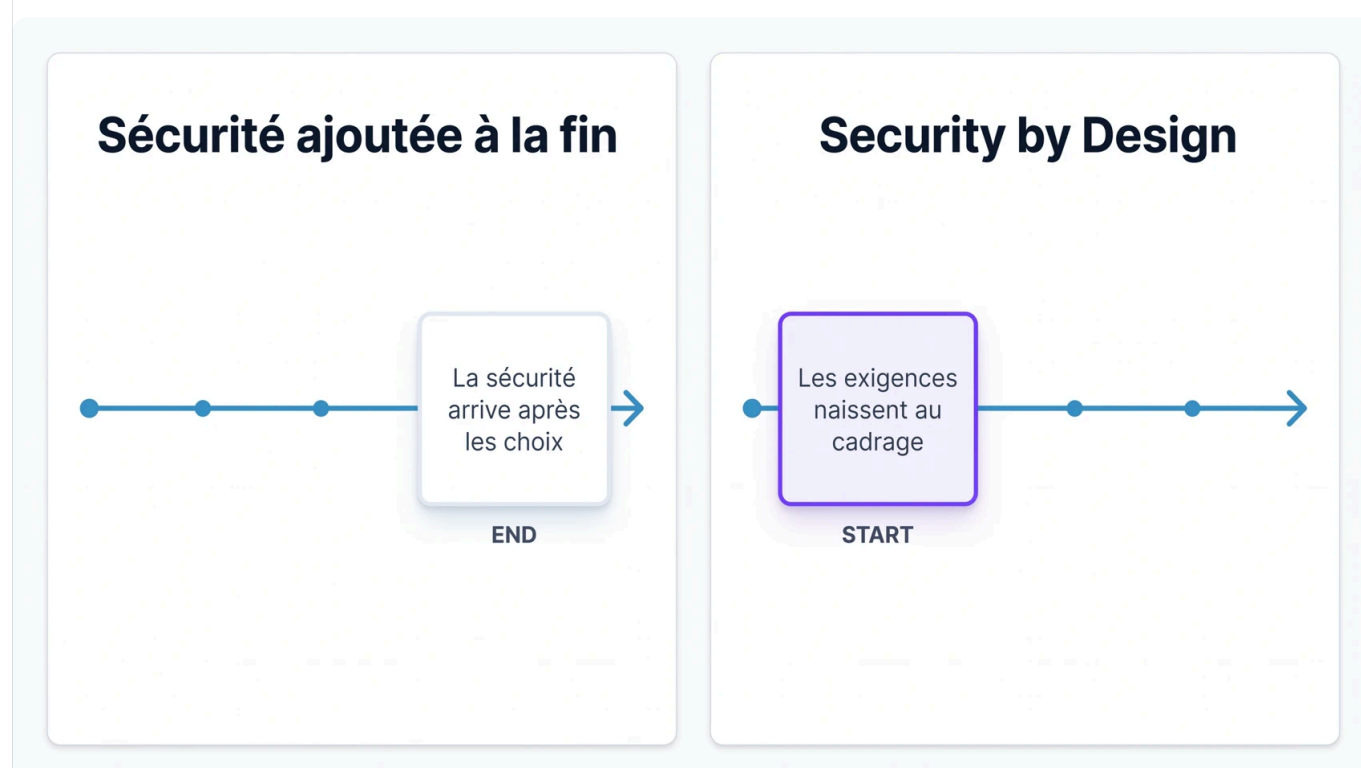


Security by Design et intégration dans les projets

✓ Sécuriser ce qui n'existe pas encore



Objectifs de la séance

À l'issue de ce cours :

- **Expliquer** ce qu'est le Security by Design, à quel problème économique et technique il répond, et ce qu'il ne garantit pas
- **Intégrer** la sécurité dans un cycle de projet réel, en plaçant des jalons de sécurité avec des critères de passage vérifiables
- **Articuler** les trois régimes d'un projet, acheter, développer, faire développer, avec les exigences qui conviennent à chacun

- **Reprendre** un projet du groupe MERIDIAN à la racine pour montrer ce que la conception aurait dû exiger d'emblée

Prérequis

- Le TD de ce matin : la chaîne d'approvisionnement, l'attaque par rebond et le recensement des dépendances tiers du groupe.
- La gouvernance de séance 1 : la PSSI (politique de sécurité des systèmes d'information) cadre et ses directives, la matrice RACI (responsable, approbateur, consulté, informé) et l'unicité du responsable ultime, le droit de dérogation encadré.
- La cartographie de séance 2 : valeurs métier, biens supports et besoins DICT (disponibilité, intégrité, confidentialité, traçabilité), qui fournissent les exigences de départ de tout projet.
- Le référentiel choisi en séance 3 et le rapport d'audit de la séance 4, qui disent respectivement ce que le groupe s'impose et où il en est.

Le problème que ce cours attaque

Ce matin, le TD a regardé les tiers déjà installés dans le système : le prestataire sous contrat, le flux de mise à jour, l'interconnexion héritée. Mais chacun de ces maillons a un point de naissance : un projet. Un jour, quelqu'un a décidé d'acheter ce logiciel, de signer ce contrat de maintenance, d'ouvrir ce flux. Et dans la plupart des organisations, la sécurité n'était pas dans la pièce ce jour-là. Elle arrive après, quand l'architecture est figée, le budget consommé, le contrat signé : il ne lui reste qu'à colmater.

Le groupe MERIDIAN en porte une illustration connue : le projet de plateforme d'apprentissage de la filiale Éducation, connectée aux bases administratives de Territoires. Le Responsable SI Territoires s'y oppose, l'affaire monte en arbitrage, et il faudra sans doute imposer après coup une DMZ (zone démilitarisée, réseau tampon) et des API (interface de programmation) sécurisées. Quel que soit l'arbitrage, le coût réel de l'épisode est déjà là : un conflit entre filiales, un délai, une architecture à reprendre. Tout cela s'achetait en une réunion si les exigences avaient été posées au cadrage.

10,6%

DES MENACES RECENSÉES PAR L'ENISA
RELÈVENT DE LA CHAÎNE
D'APPROVISIONNEMENT

ENISA, Threat Landscape 2025

85%

DES ENTREPRISES ADOPTENT DES CLAUSES DE
SÉCURITÉ DANS LEURS CONTRATS POUR
ATTÉNUER LES RISQUES LIÉS AUX TIERS

CESIN / OpinionWay, 2025

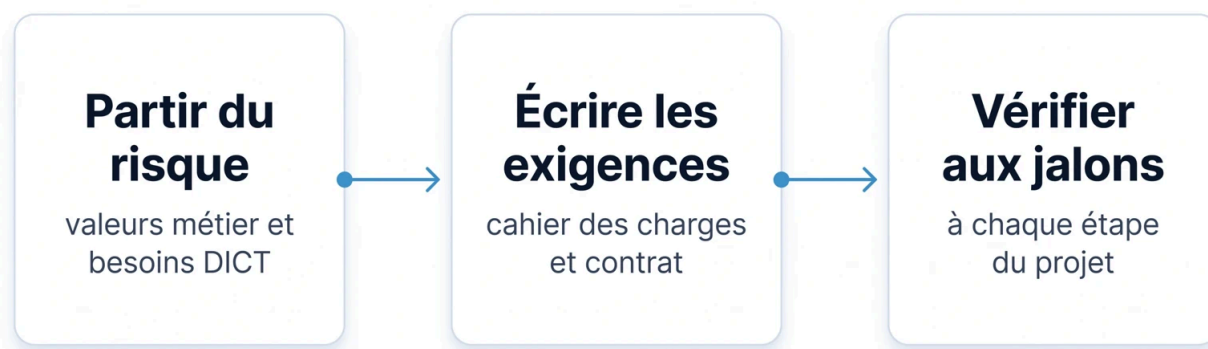
Ces deux chiffres disent la même chose par les deux bouts : la menace passe par ce qu'on acquiert et ce qu'on contracte, et les organisations l'ont compris au point d'armer massivement leurs contrats. La question de ce cours est donc : comment faire en sorte que la sécurité soit une propriété de naissance des projets, et non une rustine de fin de course.

✓ Security by Design : une exigence de naissance, pas une couche de finition

D'abord, la notion qui donne son titre à la séquence. Le problème concret vient d'être vu : la sécurité ajoutée en fin de projet se heurte à des choix déjà faits. On ne cloisonne pas facilement un réseau conçu à plat, on n'ajoute pas une authentification forte à une API dont le protocole ne la porte pas, on ne renégocie pas sans douleur un contrat signé sans clause de sécurité. Le **Security by Design**, la sécurité dès la conception, est le principe selon lequel les exigences de sécurité sont définies, arbitrées et intégrées dès le cadrage d'un projet, au même titre que les exigences fonctionnelles, puis vérifiées à chaque étape de sa réalisation. Ce n'est pas une technologie ni un document : c'est une discipline d'ingénierie et de gouvernance.

Sa mécanique tient en trois mouvements. Premier mouvement : partir du risque, pas du catalogue. Un projet commence par identifier ce qu'il va manipuler (quelles valeurs métier, quelles données, avec quels besoins de disponibilité, d'intégrité, de confidentialité et de traçabilité, ceux que la séance 2 a appris à coter) et ce qui pourrait l'atteindre. Le guide EBIOS Risk Manager v1.5 range explicitement cet usage parmi les siens : la méthode sert à « apprécier et traiter les risques relatifs à un projet numérique, notamment dans l'objectif d'une homologation de sécurité ». Deuxième mouvement : convertir ce risque en exigences datées, écrites dans les documents du projet, cahier des charges compris, car une exigence qui n'est pas écrite au moment de l'appel d'offres n'existera pas dans le contrat. Troisième mouvement : vérifier, à chaque étape, que les exigences survivent aux choix techniques, aux compromis de délai et aux avenants, ce qui suppose des points de contrôle, les jalons présentés dans un instant.

Trois principes complètent la mécanique, et le syllabus les nomme. Les valeurs par défaut sûres : un système livré fermé, que l'on ouvre au besoin, plutôt qu'un système livré ouvert que l'on referme après l'incident. Le moindre privilège dès la conception : chaque composant et chaque compte ne reçoit que les droits de sa fonction, ce qui se décide sur le schéma, pas en exploitation. La dette de sécurité : chaque jalon sauté crée une dette, remboursée plus tard avec intérêts, en reprise d'architecture ou en incident ; une exigence posée au cadrage coûte une réunion, la même exigence rattrapée en production coûte un projet.



Ce principe n'est pas une élégance de théoricien : les textes qui arrivent sur le groupe le portent. La directive NIS 2 (sécurité des réseaux et des systèmes d'information) impose, parmi ses mesures minimales de gestion des risques, « la sécurité de l'acquisition, du développement et de la maintenance des réseaux et des systèmes d'information, y compris le traitement et la divulgation des vulnérabilités » (article 21, paragraphe 2, point e). Et le référentiel que le groupe a choisi en séance 3 consacre une mesure de son annexe A à la question, visible dans l'outil, dans l'audit de la séance 4 : A.5.8, « Sécurité de l'information dans la gestion de projet ». Autrement dit : intégrer la sécurité aux projets n'est pas une préférence du RSSI (responsable de la sécurité des systèmes d'information), c'est une exigence du référentiel adopté et une obligation en devenir.

Reste sa limite, et elle est double. D'abord, le by design ne dispense de rien en exploitation : un système parfaitement conçu se dégrade dès sa mise en service si personne n'applique les correctifs ni ne surveille les journaux ; la conception ouvre bien la partie, elle ne la gagne pas. Ensuite, le principe meurt par excès autant que par défaut : un RSSI qui exige tout, partout, dès le cadrage, transforme la sécurité en bureau des refus, et les métiers apprennent vite à contourner le bureau. La proportionnalité est constitutive du principe : les exigences se calibrent sur les besoins DICT réels du projet, pas sur le maximum imaginable.

Fiche notion : Security by Design

Le problème : la sécurité ajoutée en fin de projet coûte cher, arrive tard et se négocie en position de faiblesse. **La définition** : principe selon lequel les exigences de sécurité sont définies dès le cadrage d'un projet, intégrées à ses documents contractuels et vérifiées à chaque étape. **La mécanique** : partir du risque (valeurs métier, besoins DICT, scénarios), convertir en exigences écrites, contrôler aux jalons. **La limite** : ne remplace ni l'exploitation ni la proportionnalité ; un by design maximaliste tue les projets qu'il prétend protéger.

Les jalons de sécurité : donner des dents au principe

Un principe sans point de contrôle est un vœu. La question opérationnelle est : à quels moments précis du projet la sécurité a-t-elle le droit de regarder, d'exiger et de bloquer ? La réponse s'appelle **jalon de sécurité**. Un jalon de projet, d'abord, au sens général : un point de passage daté entre deux phases, où l'on décide de continuer, d'ajuster ou d'arrêter. Un jalon de sécurité est ce même point de passage, muni de critères de sécurité explicites : le projet ne franchit le jalon que si les critères sont tenus ou qu'une dérogation motivée est accordée. L'intégration de la sécurité dans les projets, la troisième notion de ce cours, n'est rien d'autre que cela : la présence organisée de la sécurité à chaque phase, du cadrage à la fin de vie, plutôt qu'une revue unique en fin de course.

Voici la trame, sur un cycle de projet classique. Elle vaut pour un développement interne comme pour un achat, seuls les livrables changent.

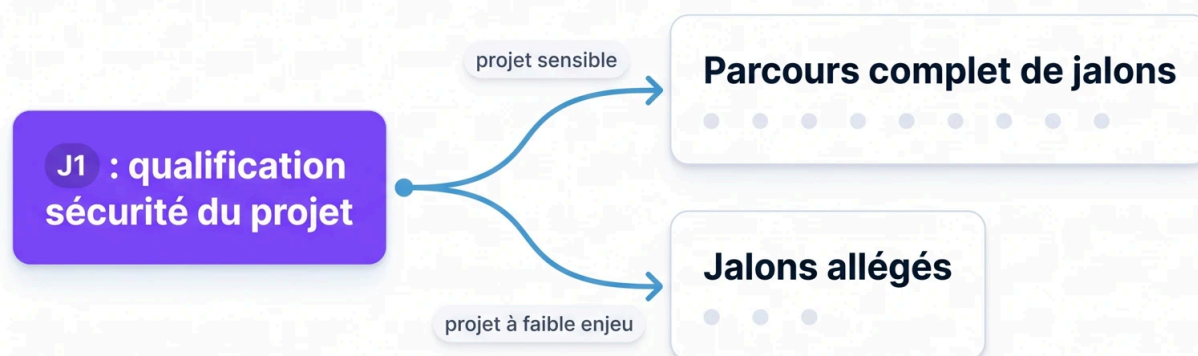
Phase du projet	Jalon de sécurité	Questions posées au jalon	Ce qui est produit
Cadrage	J1 : qualification sécurité du projet	Quelles valeurs métier et données ? Quels besoins DICT ? Quel niveau d'analyse de risque proportionné ?	Fiche projet volet sécurité, classification des données
Conception	J2 : validation de l'architecture	Les exigences sont-elles traduites dans l'architecture ? Cloisonnement, authentification, journalisation prévus ?	Dossier d'architecture, exigences de sécurité versées au cahier des charges
Réalisation ou achat	J3 : contractualisation et développement	Les exigences figurent-elles au contrat ? Le développement suit-il les règles de sécurité ?	Contrat avec clauses de sécurité, preuves de tests
Recette	J4 : vérification avant service	Les exigences sont-elles démontrées, pas seulement déclarées ? Audit ou tests d'intrusion si le niveau l'exige ?	Rapport de recette sécurité, décision de mise en service
Exploitation	J5 : conditions de vie	Qui maintient, qui surveille, qui corrige, dans quels délais ?	Conditions d'exploitation de sécurité, transfert au RSSI de filiale
Fin de vie	J6 : sortie propre	Données restituées ou détruites ? Accès révoqués ? Réversibilité exécutée ?	Procès-verbal de fin de vie

Ce tableau est l'outil de travail de l'après-midi : la fiche projet du livrable D6 en reprend la logique. Trois commentaires pour le lire en professionnel. D'abord, chaque jalon a un tenant : la gouvernance de séance 1 s'applique telle quelle, un responsable ultime unique par décision, et le RSSI n'est pas nécessairement ce tenant, il

est celui qui instruit et qui atteste. Ensuite, le jalon n'a de sens que muni d'un critère de passage vérifiable : « la sécurité a été prise en compte » n'est pas un critère, « les besoins DICT sont cotés et la classification des données est validée par le métier » en est un.

Enfin, le blocage doit être une issue réellement possible, sinon le jalon est un rituel : c'est ici que sert le mécanisme de dérogation que le groupe s'est donné, une dérogation à la PSSI cadre se motive et se valide par le RSSI Groupe sous 48 heures, elle laisse une trace et une échéance, là où un passage en force ne laisse qu'un précédent. Pour les systèmes soumis à homologation, celle travaillée en séance 4, le jalon J4 prend une forme réglementaire : la décision d'homologation est le critère de passage.

La limite des jalons se nomme d'un mot : friction. Chaque jalon coûte du délai aux projets, et un dispositif que les chefs de projet vivent comme un péage se contourne. La parade n'est pas d'alléger la sécurité mais de la proportionner : tous les projets passent J1, et c'est J1 qui décide de l'épaisseur des jalons suivants selon le risque. Un affichage interne sans données sensibles ne mérite pas le parcours d'un système de gestion de dossiers patients.



✓ Acheter, développer, faire développer : trois régimes, trois jeux d'exigences

Un projet ne fabrique pas toujours : souvent il achète, ou il fait faire. La question des tiers, ouverte ce matin, revient donc ici par la porte des projets, et c'est voulu : la meilleure maîtrise des tiers commence avant la

signature. Les trois régimes n'appellent pas les mêmes réflexes.

Régime	Ce que le groupe maîtrise	Ce que le groupe ne maîtrise pas	Levier de sécurité principal
Développer en interne	Le code, l'architecture, le calendrier	La compétence sécurité disponible en interne	Règles de développement, tests, revue de code
Acheter un produit ou un service	Le choix, la configuration, le contrat	Le code de l'éditeur, sa chaîne de fabrication, son calendrier de correctifs	Exigences dans l'appel d'offres, évaluation du fournisseur, clauses
Faire développer ou infogérer	Les exigences, le contrôle, la réversibilité	L'exécution quotidienne, les personnels du prestataire	Contrat, Plan d'Assurance Sécurité, audits, jalons contractuels

Le fil commun des trois lignes : dans tous les cas, ce qui n'a pas été exigé au départ ne pourra être que quémanté ensuite. La directive NIS 2 pousse ce raisonnement jusque chez les fournisseurs : lorsqu'une entité choisit ses mesures de chaîne d'approvisionnement, l'article 21, paragraphe 3, lui impose de tenir compte « des vulnérabilités propres à chaque fournisseur et prestataire de services direct et de la qualité globale des produits et des pratiques de cybersécurité de leurs fournisseurs et prestataires de services, y compris de leurs procédures de développement sécurisé ». À lire de près : la loi demandera d'évaluer la façon dont les fournisseurs développent.

L'annexe A du référentiel choisi couvre le même terrain en langage de mesures ; les intitulés ci-dessous sont ceux qu'affiche la bibliothèque de l'outil : relations avec les fournisseurs (A.5.19), sécurité dans les accords conclus avec eux (A.5.20), chaîne d'approvisionnement des technologies de l'information et de la communication (A.5.21), et, côté fabrication, cycle de vie de développement sécurisé (A.8.25) jusqu'au développement externalisé (A.8.30). Ces mesures ne s'apprennent pas par cœur : ce qui se retient, c'est qu'à chaque ligne du tableau ci-dessus correspond une famille de mesures déjà prévue par le référentiel du groupe.

Un mot sur le versant le plus moderne du développement, car le groupe y viendra : les chaînes d'intégration et de déploiement continus. L'ANSSI (Agence nationale de la sécurité des systèmes d'information) y consacre une fiche « Les essentiels DevSecOps », qui définit la démarche comme « une méthodologie qui vise à inclure les pratiques de sécurité dans le processus de développement et de mise en production d'applications », et qui recommande notamment de « faire une analyse de risque globale en prenant en compte les chemins de compromission des postes des développeurs, de la sous-traitance, de la chaîne CI/CD » et de « gérer les dépendances avec rigueur : les minimiser, les évaluer et appliquer les correctifs de sécurité avant déploiement ». Le motif est reconnaissable : la chaîne d'usine du logiciel est elle-même une chaîne d'approvisionnement, et l'affaire SolarWinds de 2020 a montré ce qu'il en coûte quand c'est l'usine de l'éditeur qui est compromise. Le by design ne s'arrête donc pas au produit : il couvre la fabrique du produit.

✓ Le cas MERIDIAN : reprendre la plateforme d'apprentissage à la racine

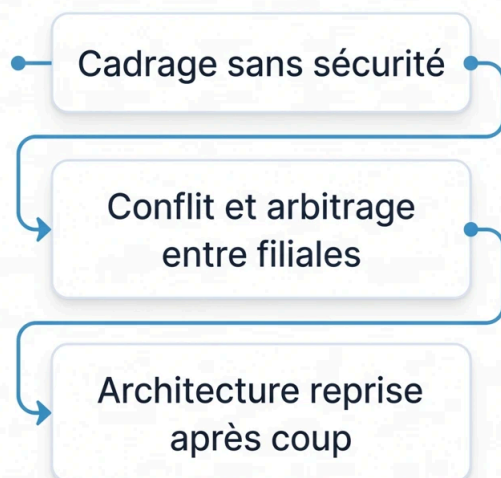
Tout le cours, appliqué à l'épisode qui l'a ouvert : la plateforme d'apprentissage d'Éducation, connectée aux bases administratives de Territoires. C'est le projet que la fiche D6 traitera cet après-midi pour le pôle Éducation et Territoires ; Santé et Logistique appliqueront la même grille au projet de leur dossier.

Le projet, rejoué avec des jalons. Au J1, la qualification aurait posé les faits en une page : le projet manipule des identités d'élèves et des données issues des bases administratives de collectivités, des données citoyennes réglementées ; la filiale porteuse a un budget restreint et un parc de logiciels tiers hétérogène ; la connexion traverse une frontière de filiales, donc une frontière de responsabilité, exactement le type de flux que la cartographie de séance 2 range dans la vue de l'écosystème. Cette page suffisait à déclencher deux conséquences : un niveau d'exigence élevé sur l'authentification, la directive de la PSSI cadre du groupe imposant déjà le MFA (authentification multifacteur), et l'invitation du Responsable SI Territoires à la table du cadrage, puisque ses données étaient en jeu.

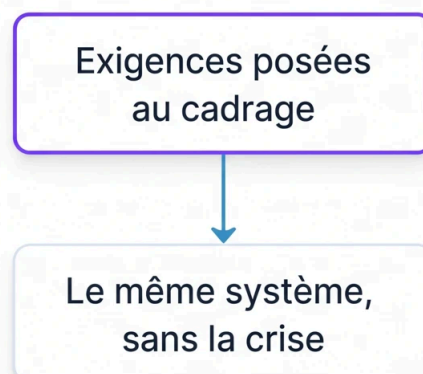
Au J2, l'architecture aurait porté d'emblée ce que l'arbitrage devra imposer après coup : une DMZ, des API sécurisées, un cloisonnement des flux. Au J3, si la plateforme est achetée ou développée par un tiers, les exigences passent au contrat, avec ce que le TD suivant apprendra à écrire : notification d'incident, droit d'audit, réversibilité. Au J4, la recette démontre, preuves à l'appui, que les flux non prévus sont bloqués. Au J5, la question « qui lit les journaux de la plateforme, et où » reçoit une réponse avant la mise en service, et l'audit de séance 4 a établi que Territoires conserve encore ses journaux localement : le projet était l'occasion de corriger, pas de reproduire.

À comparer avec ce qui se passe réellement : l'opposition d'un responsable, un arbitrage de gouvernance en cours, des mesures qui seront imposées en aval. Le résultat technique final sera proche ; le coût organisationnel, lui, n'a rien à voir. C'est la leçon générale du Security by Design : il ne produit pas des systèmes différents, il produit les mêmes systèmes sans la crise, et il transforme le RSSI d'opposant de dernière minute en co-concepteur.

Sans jalons



Avec jalons



Une dernière précision d'honnêteté intellectuelle, parce qu'un RSSI de Mastère 2 doit savoir la formuler devant une direction : concevoir sûr ne signifie pas prédire tous les scénarios. Ce matin encore, l'analyse s'arrêtait à « voici nos dépendances » ; les ateliers de la suite de la matinée apprennent précisément à raconter comment un attaquant traverserait l'écosystème, et donc à nourrir les jalons J1 et J2 avec des scénarios plutôt qu'avec des intuitions. La conception s'appuie sur l'analyse de risque ; l'analyse de risque, chez MERIDIAN, c'est la méthode entamée hier et poursuivie dans une heure.

✓ Ce qu'il faut retenir avant le TD

Trois notions sont posées et articulées. Le Security by Design : les exigences de sécurité naissent avec le projet, portées par l'analyse de risque, inscrites dans les documents, y compris contractuels. Les jalons de sécurité : six points de passage, chacun muni de critères vérifiables et d'un tenant unique, avec la dérogation motivée comme soupape gouvernée. L'intégration dans les projets : la sécurité présente à chaque phase, proportionnée par le premier jalon, et étendue aux trois régimes, développer, acheter, faire faire, jusqu'aux pratiques de développement des fournisseurs, comme la réglementation le demandera. Le TD qui suit prend le troisième régime au sérieux : quand le tiers est durablement installé dans le système, l'infogérance, comment l'analyse-t-on et comment le contrat s'écrit-il. Et l'après-midi convertira le tout en livrables : les scénarios dans l'outil, puis la fiche projet et les exigences du D6.